

VulnWeaver 中文审计报告

1. 执行摘要

被 测 样 本	packed-overflow-note（内容摘要 sha256:6863d394dd6cb24ece61bfde48e3e9a4159666adb0071387a425e389eb1374c6， 类型 ELF 二进制）
任 务 编 号	task:d894a0baab534b12b18a82f65aeb42c3
任 务 结 论	部分成功（partial）：部分分析阶段失败或受限，已产出可复核的发现；详情见附录失败原因汇总。
发 现 漏 洞 总 数	1（最高严重等级：高危（high））
确 认 状 态	不可验证（unverifiable）1 个
总 体 风 险 结 论	总体风险等级评估为高（依据最高严重等级 高危）。存在高等级问题，建议立即安排人工复核并优先处置。

主要限制

- 本次扫描未记录到阶段失败、降级或验证受阻事件。

2. 风险统计

2.1 严重等级分布

严重等级	数量
严重 (critical)	0
高危 (high)	1
中危 (medium)	0
低危 (low)	0
提示 (info)	0

2.2 确认状态分布

状态	数量
已确认 (confirmed)	0
候选 (candidate)	0
误报 (false_positive)	0
争议 (disputed)	0
不可验证 (unverifiable)	1

3. 漏洞列表

3.1【高危 · 内存破坏】Unbounded strcpy in save_note can overflow a fixed-size buffer (CWE-120)

【推测性内容】 本节缺少强证据支持，结论可能不成立，需人工复核后方可采信。

漏洞编号	finding:dc34b2fe4e846269abdcadc638f08272
严重等级	高危 (high)
可信度	0.40 (中等可信 (待验证))
状态	不可验证 (unverifiable)
类别	内存破坏 (memory_corruption)
受影响位置	0x401157 (二进制地址，函数 save_note)

触发条件与调用路径

- 漏洞目标函数 save_note (0x401157)
- 调用方 main (0x401193)
- 被调用方 printf@plt (0x401050)
- 被调用方 strcpy@plt (0x401030)

证据链明细

- 证据引用：evidence:8adaa0e1ee71f9b850554227c4f6b776, evidence:review:0da5ba1b1a1471c444b019b6aae30696cdd0fc466bb5f5de7b31c4ee3e73749c
- 复核引用：review:0da5ba1b1a1471c444b019b6aae30696cdd0fc466bb5f5de7b31c4ee3e73749c
- evidence:8adaa0e1ee71f9b850554227c4f6b776：模型推断说明 (model_explanation) ，背景信息，来源工具 vulnweaver-semantic-audit@1.0.0，工件引用 cas://sha256/c9c36fe2d06722a718e0096a858798d1b8f22cc993e72e3476e0511ab7fe7e09 (内容摘要 sha256:c9c36fe2d06722a718e0096a858798d1b8f22cc993e72e3476e0511ab7fe7e09)
- evidence:review:0da5ba1b1a1471c444b019b6aae30696cdd0fc466bb5f5de7b31c4ee3e73749c：复核结论 (review_conclusion) ，背景信息，来源工具 未提供，工件引用 cas://sha256/81f5afd3f9fdf1a2a154dba593887df91b156e65309cd746a4aaabeacaae5c47 (内容摘要 sha256:81f5afd3f9fdf1a2a154dba593887df91b156e65309cd746a4aaabeacaae5c47)

影响分析

该问题属于内存破坏类缺陷：受影响位置附近的内存访问缺乏足够的边界约束，若攻击者能控制相关输入的长度或内容，可能导致进程崩溃、信息泄露或任意代码执行。当前评估等级为高危，可信度 0.40 (中等可信 (待验证))。

修复建议

Address the audited pattern associated with CWE-120.

验证状态

- 未执行动态验证：该发现没有关联的 Poc 执行记录。

待人工确认项

- 当前状态为不可验证（unverifiable），尚未确认为真实漏洞。
- 现有证据中不含强证据，结论强度有限。

4. 附录

4.1 任务元数据

任务编号	task:d894a0baab534b12b18a82f65aeb42c3
创建时间	2026-09-11T02:36:59.662846Z
最后更新	2026-09-11T02:39:09.743218Z
报告工具	vulnweaver-report@1.0.0

4.2 失败原因汇总

- 任务结论为部分成功（partial），但未记录结构化失败原因。

4.3 复核历史

- finding:dc34b2fe4e846269abdcadc638f08272:
review:0da5ba1b1a1471c444b019b6aae30696cdd0fc466bb5f5de7b31c4ee3e73749c 结论不可验证（unverifiable）；复核模型 review-model/deepseek-flash；理由 The finding is a candidate memory corruption (CWE-120) at virtual address 4198743, but the supplied source_facts show availability=false, excerpt=null, and reason_code=source_location_unsupported. The evidence array is empty. No source excerpt or code context was read, so the review cannot establish input control, reachability of the cited location, the dangerous operation, or any protective conditions. Location offsets and image base metadata alone do not confirm a buffer overflow. Because missing evidence cannot establish a true positive and the referenced artifact contents are unavailable, the outcome is unverifiable rather than confirmed or false_positive.; 时间 2026-09-11T02:39:09.156138Z

4.4 数据说明

- 原始工具输出与运行日志以不可变工件引用保存，本报告仅嵌入引用，不复制原始内容。
- 全部结论均可追溯到扫描结果字段；字段缺失时显示「未提供」。